

# Theoretical Foundation of ZK-SNARK Video Steganography

VideoLevel technical design note

19 September 2026

## Abstract

This design note specifies the security and signal-processing model used by VideoLevel. A message is bound to a secret using a Groth16 proof, then the proof-bearing payload is embedded in H.264 CAVLC syntax at selected trailing-one sign positions. The document separates imperceptibility, payload integrity, and key authorization, and states the limits of offline expiration.

## 1 Objective and trust boundary

Let  $V$  be an H.264 elementary stream,  $m$  a non-empty message,  $k$  a 32-byte secret, and  $C$  the circuit/proving-key bundle. The embedder produces a stego stream  $V'$  and sidecars. A verifier receiving  $V'$ , an original cover in strict mode,  $k$ , and an expected message length accepts only when the extracted proof verifies and the recovered message matches that statement. The cover is not a cryptographic trust anchor; the ZK statement and signed manifest are.

Private inputs are  $m$  and  $k$ . Public evidence includes a payload hash, commitment, proof, verification key, stream metadata and an optional signed manifest. The implementation must never write  $k$  or  $m$  to job-status records, logs, manifests or benchmark artifacts. HTTP clients send them only over TLS; the worker retains them only until completion.

## 2 Video channel

H.264 CAVLC represents residual transform coefficients. For selected coefficients whose magnitude is one, their value is represented by a sign bit. Changing a selected sign bit is length-preserving at bitstream syntax level. The parser reconstructs coefficient context for IDR slices and produces a candidate set  $P = \{p_1, \dots, p_N\}$ . A safety filter removes locations that would violate parsing, local modification limits or validated visual quality.

For payload bits  $b_i \in \{0, 1\}$ , embedding changes the sign at  $p_i$  only when the current sign does not encode  $b_i$ . Extraction repeats the position derivation and reads those signs. Capacity is therefore not all coefficients: it is the minimum of syntactic candidates, patchable positions, visually validated positions and the configured operating budget. These quantities must be reported separately. The strongest current regime is all-intra H.264/CAVLC; GOP-dependent streams require separate quality and verification measurement.

## 3 Proof and payload construction

The framed payload is

$$B = \text{u32be}(|m|) \parallel m \parallel \text{Compress}(\pi),$$

where  $\pi$  is a Groth16 proof. The length field rejects truncation and prevents an ambiguous message/proof split. The circuit proves knowledge of message and key bits for

$$h_m = \text{SHA256}(m), \quad c = \text{SHA256}(h_m \parallel k), \quad 0 < |m| < 1,000,000.$$

The public input is  $(h_m, c, |m|)$  and the witness is  $(m, k)$ . Groth16 verifies that a satisfying witness existed without revealing it. The length bounds are constraints in the circuit rather than application-only checks. This proves binding to  $k$  under SHA-256 assumptions; it does not prove that the holder was authorized or that a message is semantically true.

## 4 Algorithms

### Embedding

1. Validate stream, message and key lengths; load circuit artifacts.
2. Build  $h_m, c, |m|$  and calculate  $\pi \leftarrow \text{Prove}(C; m, k)$ .
3. Frame  $B$ , optionally scramble bits and positions, derive validated positions, and patch CAVLC signs.
4. Reconstruct  $V'$  and emit non-secret metadata only.

### Verification

1. Validate the key and expected length. Strict mode parses the original cover; sidecar-assisted modes have a narrower metadata trust assumption.
2. Extract the frame, reverse optional scrambling, and reject malformed lengths or proof encodings before cryptographic work.
3. Verify  $\pi$  against  $(h_m, c, |m|)$  and return accept/reject without exposing  $m$  via public job status.

## 5 Manifest signatures and expiring keys

A manifest is canonically serialized, hashed and signed with Ed25519. A certificate separately binds a 32-byte manifest public key to a `key_id`, issuer, `not_before`, and `expires_at` UTC timestamps. The issuer signs canonical certificate bytes. A valid decision is

$$\text{Verify}_I(\text{cert}) \wedge t \in [\text{notBefore}, \text{expiresAt}] \wedge \text{Verify}_{K_{\text{cert}}}(\text{manifest}).$$

Thus a conforming offline verifier rejects an expired certificate. It cannot prevent a copied private key being used with a modified clock or verifier. Strong non-use after a deadline needs an online short-lived lease, a trusted time source, or a hardware-backed key enforcing policy. This need not be a commercial third party: the project owner can operate the authority, but an external trust anchor is unavoidable for hard time enforcement.

## 6 HTTP operational surface

The delivery API exposes public `/health` plus authenticated `embed`, `verify`, `status` and `artifact-download` jobs. Every endpoint except `health` needs `Authorization: Bearer <token>`; startup fails if `ZK_STEGO_API_TOKEN` is absent. Uploads are bounded, limited to raw H.264 extensions, and stored under random job identifiers. Jobs are asynchronous because proof generation and video analysis are costly. Persisted status JSON contains safe state and results only, never request secrets, message bytes or stack traces. Production deployment still needs TLS termination, identities, rate limits, durable job storage, audit retention and secret management.

## 7 Benchmark methodology

Each run records input hashes, codec settings, OS, CPU count and tool versions. Quality uses decoded original/stego pairs: full-video PSNR, minimum modified-frame PSNR and mean SSIM. Correctness requires proof verification and message equality. Capacity reports raw-safe, patchable, validated and operating bits separately. Security includes chi-square, SPA and RS at the same operating point. Runtime separates one-time preprocessing from per-request work. The resource runner measures wall-clock, aggregate process-tree CPU seconds and peak RSS, including Python, Node and FFmpeg descendants.

| Claim            | Evidence               | Checked baseline                  |
|------------------|------------------------|-----------------------------------|
| Imperceptibility | SEC1 decoded metrics   | 53.01 dB PSNR; SSIM 0.999686      |
| Integrity        | SEC1/SEC5 verification | 1232 bits; 147-byte proof payload |
| Latency          | SEC6 stages            | 85.03 s end-to-end                |
| Detectability    | SEC4 operating point   | chi-square p=0.9622; SPA=0.03762  |

Table 1: Artifact-specific values, not universal guarantees.

## 8 Limitations

Groth16 needs trusted setup material; protect and version proving and verification artifacts. Sidecar-assisted modes trade cover independence for metadata availability. Before untrusted Internet traffic, add a transactional job store, quotas, authenticated principals, content scanning, audit trails, HSM or secret-manager integration and a lease/revocation service when hard expiration is required.